

Why Is Application Security Testing Important and 5 Essential AST Tools

What is Application Security Testing?

[Application security](#) testing (AST) helps find and eliminate vulnerabilities in software applications. These practices and technologies enable software development and security teams to create more secure source code and protect applications against external and internal threats.

AST involves tests, analyses, and reports on a software application's security state as it progresses throughout the software development lifecycle (SDLC). The goal is to prevent vulnerabilities before software products are released into production, and rapidly identify vulnerabilities if they occur in production.

Why is Application Security Testing Important?

Security testing is the process of evaluating an application's security posture, identifying potential vulnerabilities and threats, and remediating or mitigating them. Security testing is an important step in the SDLC, which can help teams discover security issues in applications before they escalate into damaging attacks and breaches.

Application security testing can have several key benefits:

- Identifying security flaws in early stages of the development process, when they are simple and inexpensive to fix.
- Avoiding shipping software with security issues, which can have major impacts on a business, including compliance risk, legal risk, and reputation risk.
- Identifying security issues when applications are already running in production and rapidly mitigating them, to prevent attackers from causing damage.
- Continuously improving application security by identifying new vulnerabilities and threats and enhancing security measures.

Application Security Testing Techniques

Vulnerability Scanning

Vulnerability scanners can identify security vulnerabilities and flaws in operating systems and software programs. Vulnerability management programs include scanners as a core component to strengthen security and protect against security breaches. The resulting assessments of a scan help measure security readiness and reduce risks.

Penetration Testing

A penetration test (pentest) is an authorized mock attack targeting a computer system to assess its security. Pen testers attempt to identify and test the business impact of system weaknesses by utilizing techniques, tools, and processes that would-be attackers might use.

Penetration testing involves simulating various attacks that might threaten a business to verify that its security can withstand attacks from authenticated as well as unauthenticated locations and system roles.

Ethical Hacking

Ethical hacking is an authorized attempt to breach computer systems, applications, or data. It involves imitating the behavior and tactics of a malicious actor. This method can help uncover security holes before actors can exploit them.

Security Audit

A security audit involves systematically assessing an information system's security state by checking whether it conforms to established standards. A comprehensive audit evaluates the system's physical configuration and the security of its software, environment, user practices, and information processing.

5 Types of Application Security Testing Tools

1. Static Application Security Testing (SAST)

SAST tools inspect code for vulnerabilities and defects. This white box testing technique helps locate problems and bugs in source code. A SAST tool scans static code instruction by instruction, line by line, and compares each against known bugs and established rules. By default, most SAST tools contain many known bugs. Administrators can define additional issues to add to the test plan when needed.

2. Dynamic Application Security Testing (DAST)

DAST tools examine vulnerabilities in web applications during runtime. This black box technique does not involve any prior knowledge of the code. Rather, DAST tools feed or inject malicious and faulty data into the software. It runs software builds, testing the software externally using hacking techniques to detect exploitable vulnerabilities.

A DAST tool is an input simulator, providing a prescribed input—test cases that simulate a malicious attack targeting an application. The tool compares the expected output to an actual result. A discrepancy between an expected and actual result can indicate a software defect and requires further investigation.

3. Interactive Application Security Testing (IAST)

IAST combines SAST and DAST characteristics into one test, typically performed during application development. IAST can process more code than DAST or SAST, providing more reliable results and a comprehensive view of the tested application and its environment to identify more security vulnerabilities.

IAST tools analyze an application's operation, look for vulnerabilities, assess performance, and feed any detected problem directly into a tracking tool. Development teams can apply IAST software agents at any phase of the SDLC, including:

- In the integrated development environment (IDE) during coding to help assess the code base.
- During software testing phases to report on flaws and performance.
- When rolling out the built application into production to achieve ongoing security monitoring.

4. Mobile Application Security Testing (MAST)

MAST tools and techniques simulate attacks on mobile applications, combining static and dynamic analysis with investigations of the forensic data generated by the tested mobile apps. A MAST tool can look for security vulnerabilities, similarly to DAST, SAST, and IAST,

and also check for mobile-specific issues such as malicious WiFi networks, jailbreaking, and data leakage from mobile devices.

5. Software Composition Analysis (SCA)

SCA tools automatically identify open source software components in a codebase. The goal is to evaluate license compliance, code quality, and security. SCA tools can inspect codebase components, including package managers, source code, manifest files, container images, and binary files, and compile all identified open source components into a bill of materials (BOM).

Once the BOM is created, the tool compares it against various databases, such as the National Vulnerability Database (NVD) or commercial databases to identify the licenses associated with the code. The tool also uses these databases to analyze overall code quality, checking version control, history of contributions, and other aspects. Comparing the BOM against these databases helps identify critical legal issues and security vulnerabilities so teams can quickly fix them.

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a  hacker?

Trust